FinSecure Pay: application and test evidence

Business need: release a transaction validation API reliably through automated quality gates

Application source: app.py

```
@app.get("/health")
def health():
    """Return a JSON liveness status and HTTP 200
without checking dependencies."""
    return {"status": "ok"}, 200
```

Field-validation response (lines 76–79)

```
errors = validate_transaction_payload(body)
if errors:
    response = jsonify({"valid": False, "errors":
errors})
    return response, 400
```

Transaction dataclass

```
    transaction_id: str
    account_id: str
    amount: float
    currency: str
```

Build 27 console excerpts

```
#12 naming to docker.io/library/
finsecure-pay-test:27 done
#12 DONE 2.9s
+ docker run --rm finsecure-pay-test:27
collecting ... collected 39 items
```

```
39 passed in 0.37s
```

Nonblank IDs, finite numeric amounts in (0, 10000], and SGD/USD/EUR currencies. Invalid JSON, fields, and content types are tested.

GitHub repository and feature-branch history

Chua Mei Yun • 3 November 2026

Dockerfile image version and container execution

The current image uses a pinned Alpine base and a non-root Gunicorn process

Current Dockerfile

```
FROM python:3.12-
alpine@sha256:e6dae589c1c05976188fd3bd019afd091445fc533e
d2ea29001beddc7368a9c8
WORKDIR /app
ENV PYTHONDONTWRITEBYTECODE=1
ENV PYTHONUNBUFFERED=1
COPY requirements.txt .
RUN python -m pip install --no-cache-dir -r
requirements.txt
COPY app.py transaction.py ./
RUN addgroup -S -g 10001 appuser \
    && adduser -S -D -H -u 10001 -G appuser \
       -s /sbin/nologin appuser
USER appuser
EXPOSE 8000
CMD ["python", "-m", "gunicorn", "--bind",
"0.0.0.0:8000", "--access-logfile", "-", "app:app"]
```

Blank lines removed and long lines wrapped for display.

Successful image build

```
((.venv) ) (base) chuameiyun@macbook-pro capstone-finpay-cicd % docker build -t finsecure-pay:v1.0.0 .
[+] Building 10.1s (11/11) FINISHED docker:desktop-l
 => [internal] load build definition from Doc  0.0s
 => => transferring dockerfile: 578B           0.0s
 => [internal] load metadata for docker.io/li  0.0s …
 => => transferring context: 4.52kB            0.0s
 => [2/6] WORKDIR /app                         0.0s
 => [3/6] COPY requirements.txt .              0.0s
 => [4/6] RUN python -m pip install --no-cach  9.1s
 => [5/6] COPY app.py transaction.py ./        0.0s
 => [6/6] RUN groupadd --gid 10001 appuser     0.3s
 => exporting to image                         0.4s
 => => exporting layers                        0.3s
 => => writing image sha256:d144567a359b18487  0.0s
 => => naming to docker.io/library/finsecure-  0.0s
```

Versioned local image

```
((.venv) ) (base) chuameiyun@macbook-pro capstone-finpay-cicd % docker images finsecure-pay
                                                                  i Info →  U In Use
IMAGE                  ID             DISK USAGE   CONTENT SIZE   EXTRA
finsecure-pay:v1.0.0   d144567a359b       140MB             0B
```

Docker Hub registry: v1.0.0



Running container: docker ps

```
CONTAINER ID   IMAGE                  COMMAND                  CREATED          STATUS          PORTS                      NAMES
c5bf13366119   finsecure-pay:v1.0.0   "python -m gunicorn …"   8 seconds ago    Up 7 seconds    127.0.0.1:8080->8000/tcp   finsecure-pay
```

AKS manifests and health probes

Baseline manifest: v1.0.0. Jenkins injects build-N for releases. Complete YAML files are linked below.

Deployment

```
apiVersion: apps/v1
kind: Deployment
metadata:
  name: finsecure-pay
spec:
  replicas: 2
```

Container settings

```
name: finsecure-pay
image: cmyaa/finsecure-
pay:v1.0.0
ports:
  - containerPort: 8000
envFrom:
  - configMapRef:
      name: finsecure-pay-config
```

Readiness and liveness

```
readinessProbe:
  httpGet:
    path: /health
    port: 8000
  initialDelaySeconds: 5
  periodSeconds: 5
  timeoutSeconds: 2
  failureThreshold: 3

livenessProbe:
  httpGet:
    path: /health
    port: 8000
  initialDelaySeconds: 15
  periodSeconds: 10
  timeoutSeconds: 2
  failureThreshold: 3
```

ConfigMap

```
apiVersion: v1
kind: ConfigMap
metadata:
  name: finsecure-pay-config
data:
  PYTHONUNBUFFERED: "1"
  PYTHONDONTWRITEBYTECODE: "1"
```

LoadBalancer Service

```
apiVersion: v1
kind: Service
metadata:
  name: finsecure-pay-service
spec:
  type: LoadBalancer
  selector:
    app: finsecure-pay
  ports:
    - protocol: TCP
      port: 80
      targetPort: 8000
```

Cloud access automatic recovery and release rollback

Managed AKS runs two ready pods and replaces a deleted pod automatically

Two Running / Ready pods

```
((.venv) ) (base) chuameiyun@macbook-pro capstone-finpay-cicd % kubectl get pods -l app=

NAME                              READY   STATUS    RESTARTS      AGE     IP             N
 NOMINATED NODE   READINESS GATES
finsecure-pay-7dff58f77-kmz4l   1/1     Running   1 (18m ago)   19m     10.244.0.82    a
 <none>           <none>
finsecure-pay-7dff58f77-txm8h   1/1     Running   0             4m45s   10.244.0.163   a
```

External application access

```
HTTP/1.1 200 OK
Server: gunicorn
Date: Thu, 29 Oct 2026 16:36:13 GMT
Connection: close
Content-Type: application/json
Content-Length: 16

{"status":"ok"}
```

57.158.99.15/health

HTTP 200
{"status":"ok"}

Deleted pod replaced automatically

```
((.venv) ) (base) chuameiyun@macbook-pro capstone-finpay-cicd % kubectl get pods -l app=finsecure-pay -w
NAME                              READY   STATUS    RESTARTS        AGE
finsecure-pay-7dff58f77-gc728   1/1     Running   0               10m
finsecure-pay-7dff58f77-kmz4l   1/1     Running   1 (9m18s ago)   10m
finsecure-pay-7dff58f77-gc728   1/1     Terminating   0               14m
finsecure-pay-7dff58f77-gc728   1/1     Terminating   0               14m
finsecure-pay-7dff58f77-txm8h   0/1     Pending       0               0s
finsecure-pay-7dff58f77-txm8h   0/1     Pending       0               0s
finsecure-pay-7dff58f77-txm8h   0/1     ContainerCreating   0               0s
finsecure-pay-7dff58f77-txm8h   0/1     ContainerCreating   0               1s
finsecure-pay-7dff58f77-txm8h   0/1     Running             0               1s
finsecure-pay-7dff58f77-gc728   0/1     Completed           0               14m
finsecure-pay-7dff58f77-gc728   0/1     Completed           0               14m
finsecure-pay-7dff58f77-gc728   0/1     Completed           0               14m
finsecure-pay-7dff58f77-gc728   0/1     Completed           0               14m
finsecure-pay-7dff58f77-txm8h   1/1     Running             0               7s
finsecure-pay-7dff58f77-txm8h   1/1     Running             0               7s
```

New pod txm8h reached 1/1 Ready at about 7 seconds.

Forward rollout: build-17

```
deployment "finsecure-pay" successfully rolled out
finsecure-pay   2/2
cmyaa/finsecure-pay:build-17
```

Rollback: restored build-15

```
deployment.apps/finsecure-pay rolled back
```

```
deployment "finsecure-pay" successfully rolled out
```

rollout undo --to-revision=2 completed successfully.

TASK 4

Jenkinsfile automation and the failed-test gate

SCM polling triggers the declarative pipeline on the dedicated finsecure-agent

Build 27: successful execution through Deploy



Build 16: Test fails and release stages are skipped



Jenkinsfile excerpts

```
label 'finsecure-agent'
pollSCM('H/2 * * * *')
stage('Test') {
sh 'docker run --rm finsecure-pay-test:$BUILD_NUMBER'
```

Failed-test console excerpts

```
1 failed, 39 passed in 0.53s
Stage "Push" skipped due to earlier failure(s)
Stage "Deploy" skipped due to earlier
failure(s)
ERROR: script returned exit code 1
```

TASK 5

Security scan reports and release thresholds

SAST, dependency scanning, and image scanning produce separate evidence

SonarQube SAST

```
QUALITY GATE STATUS: PASSED
```

Overall Security Rating must remain A. The original CSRF finding was reviewed as a false positive for this stateless API.

Snyk dependency report

```
Tested 13 dependencies for known issues,
found 0 issues, 0 vulnerable paths.
Open Security issues: 0
```

Report used --severity-threshold=high.
Lower severities are outside this release threshold.

Trivy report comparison

Report / base OS	High	Critical
Build 25 / Debian 13.7	44	0
Build 27 / Alpine 3.24.3	0	0

```
--severity HIGH,CRITICAL --exit-code 1
```

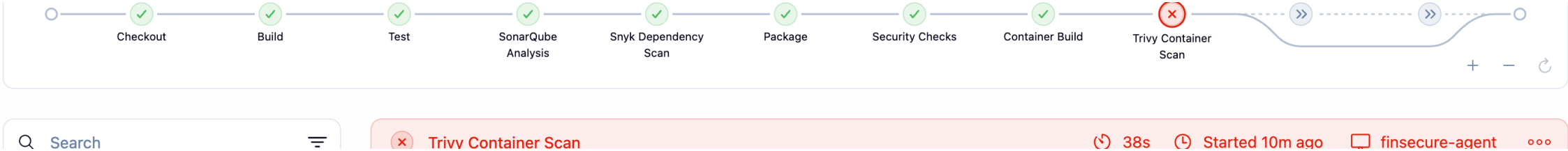
44 package/CVE entries represented 8 distinct CVEs.

TASK 5

Blocked release remediation and secure credentials

The image gate stopped release until the base-image migration passed the pipeline

Build 25: Trivy failure blocks Push and Deploy

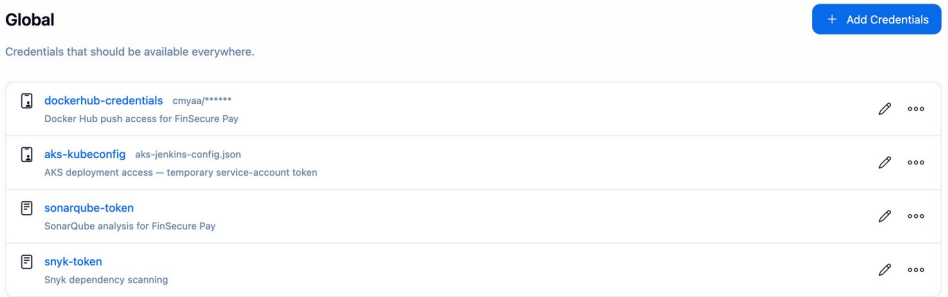


Remediation: pinned Alpine migration

```
((.venv) ) (base) chuameiyun@macbook-pro capstone-finpay-cicd % git add Dockerfile jenkins/Dockerfile.test
git commit -m "Migrate application to pinned Alpine base to address OS vulnerabilities"
git push
[feature/devsecops c11fe8c] Migrate application to pinned Alpine base to address OS vulnerabilities
 2 files changed, 5 insertions(+), 5 deletions(-)
```

Both app and test images changed. Build 27 passed 39 tests and the image gate, then pushed and deployed.

Jenkins Credentials Manager



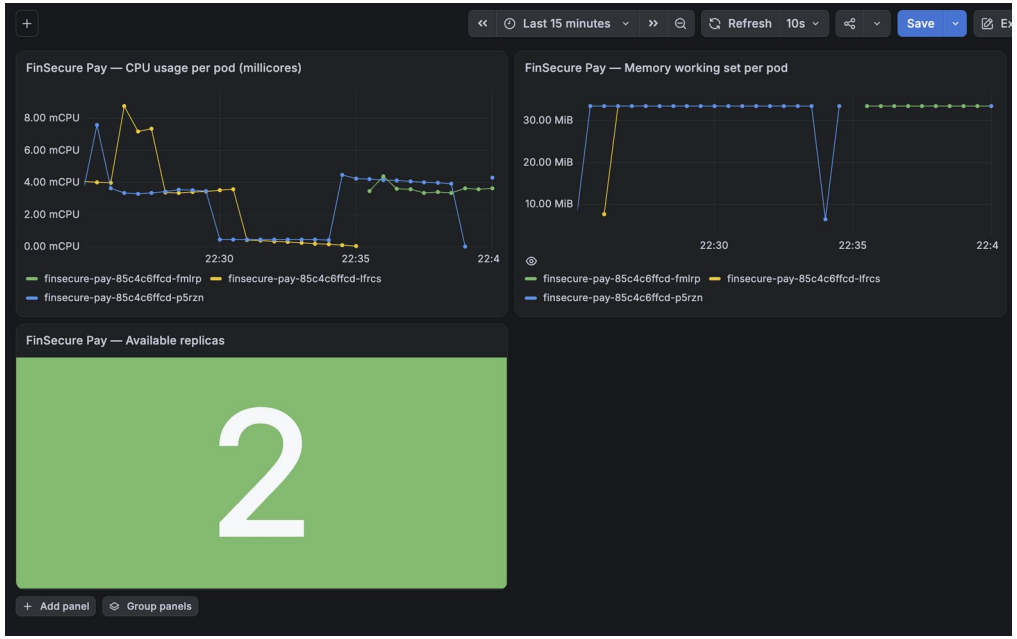
Credential IDs and types only. Secret values remain hidden.

```
NAME          READY   UP-TO-DATE   AVAILABLE   AGE     CONTAINERS    IMAGES                          SELECTO
R
finsecure-pay   2/2     2            2           2d20h   finsecure-pay   cmyaa/finsecure-pay:build-27   app=fin
secure-pay
```

Monitoring alerts and centralized application logs

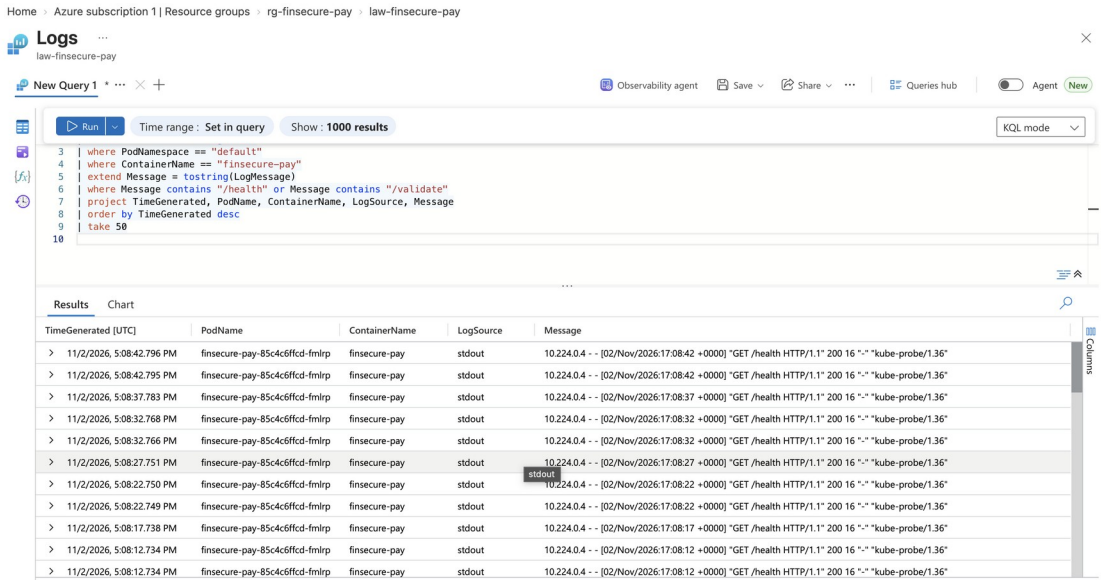
Replica alert: below 2 for 1 minute, evaluated every 30 seconds

Grafana operational dashboard



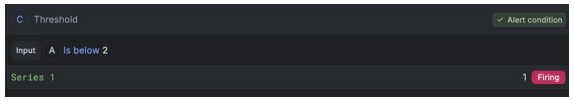
CPU (mCPU), memory (MiB), and available replicas.

Azure Log Analytics: cloud log search

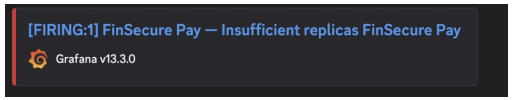


ContainerLogV2 in law-finsecure-pay. Retention: 30 days.

Grafana threshold and Firing state



Received Discord notification



kubectl logs: HTTP 400

```
7141162Z 10.224.0.4 - - [01/Nov/2026:14:54:36 +0000] "GET /health HTTP/1.
1" 200 16 "-" "kube-probe/1.36"
[pod/finsecure-pay-85c4c6ffcd-fmlrp/finsecure-pay] 2026-11-01T14:54:42.27
3547909Z 10.224.0.4 - - [01/Nov/2026:14:54:42 +0000] "POST /validate HTTP
/1.1" 400 83 "-" "curl/8.7.1"
```

AI-assisted incident triage

A read-only assistant could assemble incident evidence for an engineer to review

Problem and expected benefit

Metrics, logs, and rollout history are spread across tools. A concise evidence summary could reduce investigation time and improve handovers.

Required inputs

Alert timestamps, CPU/memory trends, pod events and logs, commit/image references, and approved runbooks.

Risks and governance

Incorrect diagnoses, sensitive-data exposure, and instructions hidden in logs. Redact inputs, cite evidence, and keep engineers accountable.

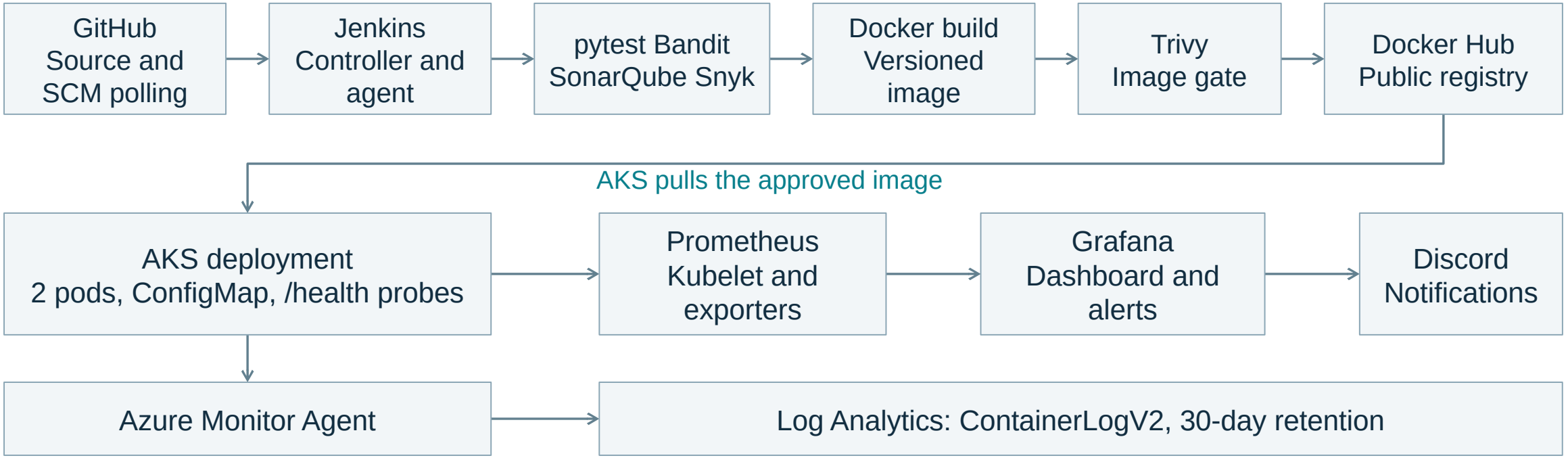
Integration and evaluation

Grafana starts a read-only collector. An approved LLM summarizes evidence for engineer review. Jenkins tests prompts and redaction rules.

Written proposal only. Engineers approve actions. Expected benefits require pilot evaluation.

Architecture design choices and project resources

Local Jenkins gates releases. AKS runs the application and monitoring.



Lessons: gates must block release. Two pods on one node share failure risk.

Next: multiple nodes, TLS/authentication, automated log redaction, and deployment by digest.

GitHub repository

Final implementation: main

Docker Hub image tags

github.com/meiyun1995/capstone-finpay-cicd